SENTINEL APPSEC | APPLICATION SECURITY VERIFICATION

https://tmvoid.github.io/lakshit-site/

Report ID: sentinel-audit-1794152591266 | Duration: 0 ms

Date: Sun, 08 Nov 2026 15:43:11 GMT | URL: https://tmvoid.github.io/lakshit-site/

CRITICAL	HIGH	MEDIUM	LOW	PASSED
0	0	2	2	10

1. Executive Verification Summary

The Sentinel AppSec engine verified 4 security finding(s) backed by empirical HTTP header responses, SPA-filtered sensitive route probes, live OSV.dev CVE advisories, or exact source code line matches, alongside 10 passed security control(s).

2. Empirical Vulnerability Ledger (4)

01. [MEDIUM] Missing Content-Security-Policy (CSP) Header

CWE-693 | A05:2021 Security Misconfiguration | Target: https://tmvoid.github.io/lakshit-site/

Summary: Neither the HTTP response headers nor HTML <meta> tags define a Content-Security-Policy.

Impact: Without a restrictive CSP, any Cross-Site Scripting (XSS) flaw or rogue third-party script can execute arbitrary JavaScript and exfiltrate user tokens to external domains.

```
GET https://tmvoid.github.io/lakshit-site/ -> HTTP 200
content-security-policy: <ABSENT>

Actual Response Headers:
server: GitHub.com
access-control-allow-origin: *
strict-transport-security: max-age=31556952
content-type: text/html; charset=utf-8
```

Remediation: Configure a strict Content-Security-Policy header restricting script-src, object-src, and frame-ancestors.

02. [MEDIUM] Missing Clickjacking Protection (X-Frame-Options / frame-ancestors)

CWE-1021 | A05:2021 Security Misconfiguration | Target: https://tmvoid.github.io/lakshit-site/

Summary: Neither X-Frame-Options nor CSP frame-ancestors is present on the HTTP response.

Impact: Malicious external sites can embed this application inside an invisible <iframe> and trick users into clicking authenticated actions (UI Redressing / Clickjacking).

```
x-frame-options: <ABSENT>
content-security-policy frame-ancestors: <ABSENT>

Actual Response Headers:
server: GitHub.com
access-control-allow-origin: *
```

Remediation: Set X-Frame-Options to DENY or SAMEORIGIN and add frame-ancestors 'none' to your Content-Security-Policy.

03. [LOW] Missing X-Content-Type-Options: nosniff Header

`CWE-16 | A05:2021 Security Misconfiguration | Target: https://tmvoid.github.io/lakshit-site/`

Summary: The server does not send X-Content-Type-Options: nosniff, allowing browsers to MIME-sniff response bodies.

Impact: Browsers may interpret user-uploaded text or image files as executable HTML or JavaScript.

```
x-content-type-options: <ABSENT>
server: GitHub.com
```

Remediation: Send X-Content-Type-Options: nosniff on all HTTP responses.

04. [LOW] Permissive Wildcard CORS Policy (Access-Control-Allow-Origin: *)

`CWE-942 | A05:2021 Security Misconfiguration | Target: https://tmvoid.github.io/lakshit-site/`

Summary: The endpoint returns Access-Control-Allow-Origin: *, permitting any external origin to read public response data via fetch/XHR.

Impact: If applied globally to authenticated or internal API routes, untrusted origins may read sensitive application responses.

```
Access-Control-Allow-Origin: *
```

Remediation: Restrict Access-Control-Allow-Origin to explicit trusted origins unless the endpoint is intentionally a public read-only API.

3. Verified Passed Security Controls (10)

[PASS] **Encrypted Transport / HTTPS Context Verified (https://tmvoid.github.io/lakshit-site/)**
`Transport verified on https://tmvoid.github.io/lakshit-site/ (HTTP 200 via TLS)`

[PASS] **HTTP Strict-Transport-Security (HSTS) Active (https://tmvoid.github.io/lakshit-site/)**
`strict-transport-security: max-age=31556952`

[PASS] **Framework Fingerprinting Headers (X-Powered-By) Suppressed (https://tmvoid.github.io/lakshit-site/)**
`No X-Powered-By or language runtime framework banners detected.`

[PASS] **Subresource Integrity (SRI) / Local Script Origin Verified (https://tmvoid.github.io/lakshit-site/)**
`All application scripts loaded strictly from origin domain`

[PASS] **Sensitive Route Protected (/.env) (https://tmvoid.github.io/lakshit-site//.env)**
`Probed /.env -> Clean 404 response with zero data leakage.`

[PASS] **Sensitive Route Protected (/.git/config) (https://tmvoid.github.io/lakshit-site//.git/config)**
`Probed /.git/config -> Clean 404 response.`

[PASS] **Sensitive Route Protected (Production Source Maps) (https://tmvoid.github.io/lakshit-site//app.bundle.js.map)**
`No raw source map tokens exposed.`

[PASS] **HTTP Verb & TRACE Restriction Verified (https://tmvoid.github.io/lakshit-site/)**
`Dangerous HTTP TRACE / TRACK methods rejected or unsupported.`

[PASS] **GraphQL Unauthenticated Introspection Protected (https://tmvoid.github.io/lakshit-site//graphql)**
`No open GraphQL introspection endpoint exposed on target.`

[PASS] **URL Redirect Query Parameters Validated Against Open Redirects (https://tmvoid.github.io/lakshit-site/)**
`Query redirection parameters strictly validated.`